

AIM

To perform an OSINT-based email enumeration assessment on the target domain using the harvester in Kali Linux and analyse the information leakage and associated social-engineering risks.

command

theharvester -d test.com -b all.

procedure

- *> open the Kali linux terminal
- *> Run the harvester command
- *> Allow the tool to collect publicly available information.
- *> Record the discovered email addresses.
- *> Record discovered subdomains, hosts and IP addresses
- *> categorize the discovered email addresses according to their likely organization role.

Risk Analysis

- *> spear-phishing
- *> credential harvesting
- *> Impersonation.
- *> Infrastructure reconnaissance
- *> social-engineering preparation.

countermeasures

*> Minimize public exposure of employee email addresses wherever possible.

*> Monitor publicly available information about employees.

*> provide regular phishing and social engineering training to employees.

*> Implement multi-factor authentication

*> use email security controls

27 AIM

To conduct an authorized phishing awareness simulation using Gophish and dummy employee accounts measure user interactions and recommend method for improving employee

procedure

*> start Gophish in the authorized lab environment.

*> Log in to the Gophish dashboard.

*> Create the dummy employee group

*> create a safe phishing awareness email template

*> configure the authorized sending email.

*> create a campaign using the dummy accounts.

*> Launch the campaign within the environment.

*> Monitor delivery, email opens and clicks.

*> Generate the campaign report.

Analysis

- *> A high delivery rate.
- *> A high open rate.
- *> A high click rate
- *> A low click rate

Recommendations

- *> conduct regular Phishing awareness
 - *> Teach employees how to identify senders.
 - *> Encourage employees to verify unusual requests
 - *> Implement MFA for important organizational accounts.
 - *> Establish an easy method for employees to report suspected phishing emails.
-

3> ATM

To perform an authorized Nmap scan against, identify available operation system information, open ports and service version and analyse.

Command

`nmap -A scanme.nmap.org`

Procedure

- *> open Kali Linux terminal.
- *> Execute the Nmap aggressive scan command.
- *> wait for the scan to complete.
- *> Record the detected open ports.
- *> Record the service names
- *> Record the OS information.

social-engineering Attack analyze

- *? Identify the technical environment
- *? create a believable pretext.
- *? use technical terminology
- *? Target IT support
- *? Attempt credential theft.

Defensive Recommendations

- *? Limit unnecessary exposure of services to Internet.
 - *? Keep OS and services updated.
 - *? Disable unnecessary open ports & services
 - *? monitor network activity for suspicious scanning
 - *? Train IT support staff to verify unusual requests.
-